Scope, contribution and outcome

Private mentor review | Focused assessment | Evidence limitations retained

Project and scope

This small AppSec portfolio assesses an existing Android learning application, com.minlish.app. The focus is password-reset deep-link logging, isolated Firebase authorization evidence and client-side authentication-state manipulation. It is not a comprehensive penetration test or a claim that the application is fully secured.

The Android application is attributed to dangpham258/MinLish-AndroidApp. Personal contributions are security analysis, targeted logging remediation/static verification, local authorization-lab analysis, Frida instrumentation research, Debug diagnostics and a Python/SQL log analyzer. The entire upstream application is not claimed as original work.

What the findings establish

T-01: supplied synthetic before/after logs support the limited logging observation. Two current source statements were verified static; runtime NavGraph remediation remains NOT VERIFIED.

T-02: the supplied local image supports selected cross-user denials and one own-read allowance. Local authorization coverage is PARTIAL, not proof of production security or exploitation.

T-03: enumeration and a manipulation recipe are visible. The complete state-change/UI/Firebase-session chain is not independently retained; UI bypass remains historical assessor-reported / PARTIALLY VERIFIED.

Supporting work, not additional findings

RootDetector and InstrumentationDetector are optional Debug telemetry. Archived results show 10 and 11 unit tests PASS respectively. Root runtime has four INCONCLUSIVE observations, without rooted-device positive proof. Instrumentation records include NOT_DETECTED, INCONCLUSIVE and DETECTED; detection is not prevention or backend authorization.

The Python 3.12/SQLite analyzer uses only the standard library, validates tagged Logcat/JSONL input and handles identical/conflicting duplicates. The full handoff verified 7 tests, 4 stored/CSV rows, unchanged row count on reimport and summary INCONCLUSIVE=2, DETECTED=1, NOT_DETECTED=1. Four mixed-state events are not four attacks or an accuracy estimate. No tests were rerun for this editorial reduction.

Evidence and appendix

Only E01-E04 are included here. Code, scripts, the detailed matrix and full review records remain in the separate 71-file technical appendix, not in Quick Review. The eight privacy/rights-held images remain NOT INCLUDED. Reading this report does not require the appendix; START-HERE explains optional access.

T-01 | Sensitive deep-link logging

Synthetic logs: DIRECT | Two source sinks: STATIC VERIFIED | NavGraph runtime: NOT VERIFIED

Description

The original MainActivity deep-link logger recorded the full incoming URI. Reset links can carry sensitive reset values, so an unredacted logger could expose such input. The demonstrated test used the synthetic path value FAKE_TEST_CODE_001, not a real reset credential or a successful password-reset flow.

Evidence

E01 - before-fix log contains two MinLishApp lines with the synthetic marker. E02 - after-fix log contains no marker and one "Deep link received (URI omitted)" message. Neither capture contains NavGraph lines.

The static review recorded constant URI-omitted messages at MainActivity.kt line 45 and NavGraph.kt line 42, with source hashes in the appendix. Android source, JADX screenshots and APKs are NOT INCLUDED here. Static verification is not a new runtime result.

The logs show month/day and clock time, without embedded year/timezone or a complete APK/run binding. Their reported date context is 28 October 2026. These are historical captures, not logs generated for this package.

Impact

CWE-532; Low, provisional. A real reset value could lose confidentiality if it reached this logger and an unauthorized reader obtained the output. The test established synthetic logging, not those exploitation prerequisites. No unauthorized log access, valid credential theft or account takeover is demonstrated.

Remediation

The two targeted source statements now use the constant message "Deep link received (URI omitted)". The historical filtered MinLishApp capture supports a limited post-fix safe-message observation.

Keep diagnostic messages free of full URIs/reset values. Closing runtime remediation would require both sinks to execute in an approved isolated Debug test with synthetic input, retained timestamps and installed-build identity. That test was not performed for this reduction.

Limitations

Runtime NavGraph remediation, patched Release runtime, a current build-bound retest and application-wide sensitive-logging clearance remain NOT VERIFIED or NOT TESTED. A marker-free filtered log alone does not establish that both sinks executed. The finding is not presented as fully remediated across the application.

T-02 | Firebase authorization evidence

Local observations: DIRECT, limited | UID-rule verification: PARTIAL | Production access: NOT DEMONSTRATED

Description

The assessment separates a historical Firebase Console editor/Rules Playground observation from synthetic local Emulator tests and configuration inspection. A displayed time condition is not an ownership policy; a current rules file does not establish deployment or effective rules.

The source review recorded now < 1782320400000, expiring 24 June 2026 at 17:00 UTC (25 June, 00:00 UTC+07). Exact screenshot capture time, authentication controls, deployment history and current production rules are NOT VERIFIED. The visible denied set was a simulation, not a production data operation.

Evidence

E03 - local authorization image shows User B reading and writing User A vocabularyStates paths with HTTP 401, and one User A own-read with HTTP 200. The response body is not shown. The own-write command is visible but its result is clipped.

The original offline review contains 60 scenario rows: 7 DIRECT EVIDENCE, 17 ASSESSOR-REPORTED and 36 NOT TESTED. This is an evidence inventory, not 60 executions or a pass rate; one direct row is an administrator fixture control.

Protected Console, baseline and permissive-public-read images are NOT INCLUDED in either review package. Their historical observations remain documented in the appendix, but cannot be independently checked here. T-02 captures used the demo namespace ending -default-rtdb; E03 uses demo-minlish-security-lab without that suffix. Their rule/test histories must not be merged.

Impact

Time-only broad grants could expose data if active before expiry with relevant records present. Historical deployment and real production impact were not established, so no definitive production-impact score is assigned. The deliberately permissive public-read reproduction was local and synthetic; unauthorized production access is not demonstrated.

Remediation

UID-scoped local rules exist for users, vocabularyStates and reviewHistories, with root denial. This is implementation evidence, not a production deployment or complete authorization result. Ownership expectations and effective namespace/rules should be tied to actual positive/negative results before broader claims.

The retained users script has two read assertions but lacks execution output; setup writes bypass rules. Its existence is not a 2/2 PASS. Normal-user write/delete claims without output remain assessor-reported. No rules were changed or deployed for Quick Review.

Limitations

Lab authorization evidence remains PARTIAL. E03 does not prove repeated own-reads, unchanged target data, successful own-write/delete or exact effective-rule identity. reviewHistories UID-policy combinations and local decks/deck_vocabularies cases lack test evidence. The separate app /decks Permission denied claim remains REPORT ONLY, without an independent raw log or endpoint binding.

T-03 | Client-side state manipulation

Static navigation trace: VERIFIED | Full runtime chain: PARTIALLY VERIFIED / REPORT ONLY

Description

AuthViewModel exposes a MutableStateFlow login flag observed by NavGraph; true drives navigation to Deck. The hypothesis is that an authorized local Frida instrumenter can change this UI state without creating a Firebase session. Local instrumentation capability is a precondition; this is not a remote account-takeover claim.

Evidence

E04 - Frida enumeration image shows two instances with State:false and script text that accesses _isUserLoggedIn and requests true. It does not show a successful AFTER:true output, Login/Deck screenshots or a Firebase SDK-state result.

The appendix includes the extracted state-manipulation and getCurrentUser recipes. They are review scripts, not recovered execution transcripts. Historical Login-to-Deck navigation, a signed-out SDK state and a /decks denial were assessor-reported; the complete same-run chain has no independent retained artifact.

Impact

The local-state/navigation design is established statically. The claimed UI effect remains PARTIALLY VERIFIED; conditional Low severity concerns that reported UI effect only. A Deck screen alone would not establish protected data access. No Firebase Authentication bypass, backend authorization bypass or account takeover is demonstrated.

Remediation

Derive navigation from actual Firebase auth-state/session changes and show a signed-out/error state after session loss. Treat the UI flag as presentation state, not a security boundary. Enforce authorization independently for every protected backend read/write/action.

Client hardening or detection cannot make in-process state immutable to a privileged instrumenter. No client remediation or T-03 regression result is claimed. Complete proof would need a coherent baseline, real before/after mutation output, UI captures and actual SDK state; no missing output was reconstructed.

Limitations

The complete hooking runtime chain is not independently retained. Firebase signed-out state and /decks Permission denied remain REPORT ONLY. The separate local authorization image E03 does not establish the app SDK session or the same Frida run. Runtime detection evidence does not close this gap.

Overall conclusion

This v1.0 package supports focused mentor feedback on analysis, bounded remediation, evidence discipline and the analyzer contribution. It does not close all original project criteria. Android source/APKs, credentials, held images and production testing are outside this delivery; private review is not public-release permission.